

Controls and compliance checklist

Does Botium Toys currently have this control in place?

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.

- ☐ ☒ Sensitive data (PII/SPII) is confidential/private.
 - ☒ ☐ Data integrity ensures the data is consistent, complete, accurate, and has been validated.
 - ☐ ☒ Data is available to individuals authorized to access it.
-

Recommendations:

The findings of the security audit for the company Botium Toys show that there's a lack of controls which puts the organization on a **high** level of risk. To ensure the confidentiality, Integrity and availability of information there are some essential controls that should be implemented, these include: Encryption, Least Privilege, backups, separation of duties, IDS and IPS (optimally), disaster recovery plans, while monitoring and maintenance for legacy systems exist, intervention methods need to be specified and made more clear, so that security teams can mitigate potential risks and threats appropriately, and although the organization features password policies, their complexity requirements need to be addressed, in combination with a password management system to enforce the policies.

There is a noticeable gap in compliance, credit card information is accepted, processed, transmitted, and stored locally in the company's internal database, but there's a risk because the access is not restricted to employees that don't need that information to complete their daily work. Some of the controls mentioned previously will also help to achieve compliance while also reducing the attack surface, strengthening the organization's security posture and minimizing risk. Asset classification is also paramount to determine additional security controls needed. Compliance needs to be reviewed for ensuring the organization continues with their operations locally or abroad with a minimal level of risk, and avoiding possible compliance fines or other repercussions.